2

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad / Öğrenci No	Grup	Tarih
Mehmet Emin Yılmaz · No: 235541078	**Gece B**	**25.10.2026**

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi (Variaxis J-500'e uyarlanmıştır)
Mazatrol CNC (üretim kontrolü) · **Emniyet PLC'si** · operatör paneli/HMI · servo ve işmili sürücüleri · DNC / MES / ERP bağlantısı · **internete açık uzak bakım modülü** · bulut telemetri · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · "admin/admin" servis hesabı *(senaryo varsayımı)*

1 **Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.**
Z1 – Emniyet Bölgesi: Emniyet PLC'si + kapı kilidi/E-stop/onay şalteri + STO girişleri (en kritik, ağdan izole). **Z2 – Makine Kontrol Bölgesi:** Mazatrol CNC · operatör paneli/HMI · servo ve işmili sürücüleri. **Z3 – Fabrika Ağı / DMZ:** DNC-MES-ERP sunucuları, G-kod dosya sunucusu, jump server. **Z4 – Dış / Güvenilmeyen Bölge:** uzak bakım modülü (bugünkü haliyle), bulut telemetri, Wi-Fi AP, harici USB, "admin/admin" servis hesabı.

2 **Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?**
Bugün internete doğrudan açık olduğu için **Z4'e** düşer; ama kontrol ağına köprü kurduğundan fiilen Z2/Z3'ün içine uzanır. **Mevcut haliyle orada KALAMAZ:** aradaki denetim noktası olmadan internetten Mazatrol CNC'ye, oradan Emniyet PLC'sine ulaşılabilir; düşük güvenli bölgeden yüksek kritiklikli bölgeye doğrudan yol olmaz. Çözüm: modül Z4'te kalır, erişim yalnızca Z3'teki jump server üzerinden (VPN + MFA) ve yalnızca gerektiğinde açılır.

3 **Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?**
C1 (Z4→Z3): VPN + MFA, jump server, kişisel hesap, tam oturum kaydı, zaman pencereli onay. **C2 (Z3→Z2):** güvenlik duvarında yalnızca izinli IP/port/protokol; G-kod için dosya bütünlüğü (hash/imza) ve program onayı; makineye komut değil dosya/iş emri. **C3 (Z2→Z1):** yalnızca tanımlı donanım sinyalleri; Emniyet PLC'ye ağdan yazma yok, programlama portu anahtarlı/yerinde. **C4 (USB/Wi-Fi→Z2/Z3):** kilitli USB portu, kiosk'ta tarama; Wi-Fi ayrı VLAN, kontrol bölgesine yol yok.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server** — tek denetim noktası; kontrol bölgesi internete doğrudan görünmez, oturum kaydı ve yetki kontrolü burada yapılır.
Tünel?	Açık / VPN	**VPN** — açık port yayımlanmaz; trafik şifreli ve kimliği doğrulanmış gelir, internetten tarama/saldırı yüzeyi kapanır.
Kimlik?	Parola / MFA	**MFA** — parola sızsa veya tahmin edilse bile ikinci faktör olmadan giriş yapılamaz.
Hesap?	Paylaşılan / Kişisel	**Kişisel** — kim ne yaptı izlenebilir, en az yetki verilir, ayrılan kişinin hesabı kapatılır; "admin/admin" kaldırılır.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı** — olay sonrası kanıt (Lab 6/CRA) ve G-kod/parametre değişikliklerinin izi için şart.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı** — servis talebi + onayla zaman penceresi (ör. 2 saat) açılır, süre dolunca kapanır; saldırı yüzeyi çoğu zaman sıfır.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur. *Not: Mimari ayrıntılar eğitim amaçlı varsayımdır; üretici dokümanıyla doğrulanmalıdır.*